

Essential Activities for Secure Software Development

O desenvolvimento de software seguro envolve mitigar riscos a níveis mínimos por meio de um ciclo de vida estruturado (SSDC), garantindo confidencialidade, integridade, disponibilidade e não-repúdio. Para isso as organizações devem adotar práticas essenciais de proteção em camadas.

Princípios e Práticas de OWASP

- Perímetro e superfície de ataque: Criar barreiras em seções críticas e reduzir pontos de entrada para limitar o alcance de invasões.
- Modelos positivos: Validar apenas formatos aceitáveis, bloqueando preventivamente ameaças desconhecidas.
- Folha segura e privilégio mínimo: Restringir acessos ao mínimo necessário e garantir que falhas em mecanismos barrem a execução por padrão.
- Monitoramento e Desconfiança: Detectar intrusões, via análise de registros e nunca confiar implicitamente na infraestrutura ou em serviços externos.

A abordagem por Fase do Projeto

- Requisitos: Devem anteceder o código, utilizando simulações de casos de mau uso para mapear brechas.
- Design e Arquitetura: É a fase mais crítica. A modelagem de ameaças é a técnica mais eficaz para mitigar falhas lógicas antes da codificação.
- Implementação: Foco em programação defensiva e no uso de controles e APIs consolidados, evitando soluções caseiras.
- Testes de Segurança: Validam a conformidade do sistema, podem ser manuais, automatizados, baseados em risco, ou testes de invasão.

Modelos de Referência

O mercado se apoia em modelos prescritivos (como diretrizes de Microsoft, CLASP e DevSecOps), que ditam as ações em cada etapa, e modelos descritivos (OpenSAMM e BSIMM), que servem como referência de maturidade para comparar empresas.

CLASP

CLASP (Cloud Security Checklist) é um modelo prescritivo criado pela Microsoft para ajudar as organizações a avaliar e melhorar a segurança de suas nuvens. Ele fornece uma lista de verificação com 100 itens, organizados em 10 categorias, que cobrem aspectos como configuração, monitoramento, resposta a incidentes e governança. O modelo é baseado em melhores práticas e é atualizado regularmente para refletir as mudanças no cenário de segurança da nuvem.

OpenSAMM

OpenSAMM (Open Source Assessment of Maturity Model) é um modelo descritivo criado pela IBM para avaliar a maturidade das organizações em termos de segurança da nuvem. Ele fornece uma estrutura de avaliação com 10 domínios de segurança, cada um com 5 níveis de maturidade, variando de "Não Implementado" a "Automatizado". O modelo é baseado em melhores práticas e é atualizado regularmente para refletir as mudanças no cenário de segurança da nuvem.